

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-04 07:00 WIB

Top 5 Highlights

- Unpatched Flaws Disclosed in Filesystem Bundled Into Millions of Embedded Devices
- New "Bad Epoll" Linux Kernel Flaw Lets Unprivileged Users Gain Root, Hits Android
- CVE-2026-14660 | code-projects Online Job Portal 1.0 login.php txtUser/txtPass sql injection
- CVE-2026-14659 | itsourcecode Hospital Management System 1.0 /patientappointment.php paciente sql injection
- CVE-2026-14657 | code-projects Assessment Management 1.0 Database Query marking-scheme.php squestions[] sql injection

Threat Intelligence (10)

01. New Avalon Malware Framework Packs CrownX Ransomware Capabilities

Cybersecurity researchers have discovered a previously undocumented modular malware framework codenamed Avalon that's distributed by means of a multi-stage phishing chain capable of bypassing traditional security controls. Avalon combines credential collection, lateral movement, remote access, recovery disruption, and ransomware execution, bringing together...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/07/new-avalon-malware-framework-packs.html>

02. AdaptHealth says attackers sweet-talked their way into cloud systems and stole patient data

Third-party contractor compromise exposed health information and insurance billing passwords

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/07/03/adapthealth-crooks-stole-our-passwords-patient-health-data/5266512>

03. ARToken PhaaS exposes EvilTokens' Microsoft 365 phishing toolkit

A new phishing-as-a-service (PhaaS) platform dubbed "ARToken" appears to operate as an affiliate of the EvilTokens phishing platform, giving researchers a glimpse into an extensive toolkit designed to compromise Microsoft 365. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/artoken-phaas-exposes-eviltokens-microsoft-365-phishing-toolkit/>

04. Armored Likho Targets Government Agencies, Power Sector with BusySnake Stealer

A previously undocumented threat actor known as Armored Likho has been attributed to cyber attacks targeting government agencies and the electric power sector across Russia, Brazil, and Kazakhstan. "Armored Likho blends financially motivated campaigns targeting private individuals with targeted cyber espionage aimed at organizations," Kaspersky said in a te...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/armored-likho-targets-government.html>

05. Verified X ad spreads Mac malware, while ConsentFix steals Microsoft accounts

Two new campaigns show how cybercriminals are increasingly relying on social engineering instead of software exploits to compromise devices and accounts.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/news/2026/07/verified-x-ad-spreads-mac-malware-while-consentfix-steals-microsoft-accounts>

06. NetNut cracked as Google and FBI target 2 million-device botnet

Other residential proxy brands may rely on the same network

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/07/03/netnut-cracked-as-google-and-fbi-target-2-million-device-botnet/5266414>

07. Armored Likho digging a snake pit: inside the covert BusySnake Stealer campaign

An inside look at the active Armored Likho APT campaign. The attackers are using spear-phishing, AI-generated loaders, and a new Python-based tool, BusySnake Stealer, to target organizations in Russia, Kazakhstan, and Brazil.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://securelist.com/tr/armored-likho-apt-with-busysnake-stealer/120292/>

08. FBI, Google Take Down NetNut Proxy Network Used by Cyber Threat Actors

The NetNut proxy network and the 'Popa' botnet are known to have infected devices with variants of Mirai DDoS botnets

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/fbi-google-take-down-netnut-proxy/>

09. [+24h Old] FBI Seizes NetNut Proxy Platform, Popa Botnet

The Federal Bureau of Investigation (FBI) said today it worked with industry partners to seize hundreds of domains associated with NetNut, a sprawling residential proxy service operated by the publicly-traded Israeli company Alarum Technologies [NASDAQ: ALAR]. The action comes roughly two weeks after KrebsOnSecurity published findings from multiple security...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://krebsonsecurity.com/2026/07/fbi-seizes-netnut-proxy-platform-popa-botnet/>

10. [+24h Old] OpenBlow Multiple Deanonimization Vulnerabilities

Posted by Red Nanaki via Fulldisclosure on Jul 02 OpenBlow Multiple Deanonimization Vulnerabilities Summary A production deployment was observed (HTTP archive of a full, real whistleblower submission) to route its anonymous reporting flow through Google. The intake CAPTCHA is Google reCAPTCHA, enforced as a mandatory, server-validated gate on report submiss...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/15>

Latest Vulnerabilities (10)

01. Unpatched Flaws Disclosed in Filesystem Bundled Into Millions of Embedded Devices

Security firm runZero has disclosed seven vulnerabilities in FatFs, a small filesystem library that lets a device read and write the FAT and exFAT formats used on USB drives and SD cards. The flaws matter because FatFs is nearly everywhere. It ships inside the firmware that runs security cameras, drones, industrial controllers, hardware crypto wallets, and...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/unpatched-flaws-disclosed-in-filesystem.html>

02. New "Bad Epoll" Linux Kernel Flaw Lets Unprivileged Users Gain Root, Hits Android

A newly disclosed Linux kernel flaw called Bad Epoll (CVE-2026-46242) lets an ordinary user with no special access take full control of a machine as root. It affects Linux desktops, servers, and Android, and a fix is out. Bad Epoll sits in the same small stretch of kernel code where Anthropic's most powerful AI model, Mythos, recently found a different bug....

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/new-bad-epoll-linux-kernel-flaw-lets.html>

03. CVE-2026-14660 | code-projects Online Job Portal 1.0 login.php txtUser/txtPass sql injection

A vulnerability was found in code-projects Online Job Portal 1.0 . It has been rated as critical . The affected element is an unknown function of the file login.php . Performing a manipulation of the argument txtUser/txtPass results in sql injection. This vulnerability was named CVE-2026-14660...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376174>

04. CVE-2026-14659 | itsourcecode Hospital Management System 1.0 /patientappointment.php patiente sql injection

A vulnerability was found in itsourcecode Hospital Management System 1.0 . It has been declared as critical . Impacted is an unknown function of the file /patientappointment.php . Such manipulation of the argument patiente leads to sql injection. This vulnerability is uniquely identified as CVE-2026-14659...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376173>

05. CVE-2026-14657 | code-projects Assessment Management 1.0 Database Query marking-scheme.php squestions[] sql injection

A vulnerability was found in code-projects Assessment Management 1.0 . It has been classified as critical . This issue affects some unknown processing of the file /lecturer/marking-scheme.php of the component Database Query Handler . This manipulation of the argument squestions[] causes sql injection. This vulnerability is handled as CVE-2026-14657...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376172>

06. CVE-2026-14658 | code-projects Assessment Management 1.0 marking-scheme.php smarksrange[] sql injection

A vulnerability was found in code-projects Assessment Management 1.0 and classified as critical . This vulnerability affects unknown code of the file /lecturer/marking-scheme.php . The manipulation of the argument smarksrange[] results in sql injection. This vulnerability is known as CVE-2026-14658...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376171>

07. CVE-2026-14656 | code-projects Assessment Management 1.0 /admin/remove-user.php ID cross site scripting

A vulnerability has been found in code-projects Assessment Management 1.0 and classified as problematic . This affects an unknown part of the file /admin/remove-user.php . The manipulation of the argument ID leads to cross site scripting. This vulnerability is traded as CVE-2026-14656...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376170>

08. CVE-2026-58379 | GIMP PSP Image heap-based overflow (EUVD-2026-41560)

A vulnerability, which was classified as critical , has been found in GIMP . Affected by this vulnerability is an unknown functionality of the component PSP Image Handler . Performing a manipulation results in heap-based buffer overflow. This vulnerability is reported as CVE-2026-58379 . The attack is possible to be carried out remotely. No exploit exists.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376168>

09. CVE-2026-14654 | SourceCodester Simple and Nice Shopping Cart Script 1.0 girlsproductdeletequery.php user_id sql injection

A vulnerability classified as critical was found in SourceCodester Simple and Nice Shopping Cart Script 1.0 . Affected is an unknown function of the file /admin/girlsproductdeletequery.php . Such manipulation of the argument user_id leads to sql injection. This vulnerability is documented as CVE-2026-14654...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376167>

10. CVE-2026-14652 | SourceCodester Simple and Nice Shopping Cart Script 1.0 Admin Login /admin/login.php Username sql injection

A vulnerability described as critical has been identified in SourceCodester Simple and Nice Shopping Cart Script 1.0 . This affects an unknown function of the file /admin/login.php of the component Admin Login . The manipulation of the argument Username results in sql injection. This vulnerability is cataloged as CVE-2026-14652...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/376165>

Data Breach & Cybercrime (10)

01. The Good, the Bad and the Ugly in Cybersecurity - Week 27

FBI apprehends IRGC-linked cybercriminal, Russian hackers steal Signal backup keys, and unknown hackers breach the DHS information network.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-27-7/>

02. Qilin Dominates Ransomware Market Amid Growing Cybercrime Consolidation

The ransomware landscape is reconsolidating around major players, with Qilin emerging as the leading RaaS operation, researchers say

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/qilin-dominates-ransomware-market/>

03. Warning Over “Industrialized” Cyber-Attacks After Ransomware Gang Partners With TeamPCP

Researchers warn that collaboration could lead to “unprecedented” ransomware attacks, as FBI also issues warning

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/industrialized-cyberattacks/>

04. Medtronic Data Breach Impacts 3.8 Million People

In April, ShinyHunters accessed the company’s corporate IT systems and stole patients’ personal and medical information. The post Medtronic Data Breach Impacts 3.8 Million People appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/medtronic-data-breach-impacts-3-8-million-people/>

05. [+24h Old] Aussies Face Reduced Cybercrime Risk, as Pressure Shifts to SMBs

Improved institutional safeguards and stricter regulations have pushed the burdens of protection and risk reduction on to Australian businesses.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cybersecurity-analytics/aussies-face-reduced-cybercrime-risk-pressure-shifts-smb>s

06. [+24h Old] DHS investigating breach of intelligence sharing platform

Hackers reportedly gained access to HSIN servers in late May and early June, potentially exposing sensitive but unclassified information.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/dhs-investigating-breach-of-intelligence-sharing-platform>

07. [+24h Old] 1st 'agentic ransomware' JADEPUFFER invades database at machine speed

The LLM fixed a failed login attempt within 31 seconds, demonstrating real-time adaptability.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.scworld.com/news/1st-agentic-ransomware-jadepuffer-invades-database-at-machine-speed>

08. [+24h Old] FortiBleed Actors Collaborating With Inc, Lynx Ransomware Gangs

After gaining a foothold in thousands of Fortinet firewalls, the attackers are starting to monetize that access, and are also piling on a Nextcloud zero-day bug.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.darkreading.com/threat-intelligence/fortibleed-actors-inc-lynx-ransomware-gangs>

09. [+24h Old] Whistleblowersoftware.com: confidentiality and anonymity leakage to third parties

Posted by Red Nanaki via Fulldisclosure on Jul 02 Whistleblowersoftware.com: confidentiality and anonymity leakage to third parties ## Summary The anonymous reporting flow on `whistleblowersoftware.com` encrypts report text end-to-end in the browser but does not extend the same guarantee to attachments and exposes the reporter's network identity and timing...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/16>

10. [+24h Old] Ransomware Thugs Masquerade as Interpol to Entice Small Biz

The ransomware campaign relies on basic social engineering and stretches across multiple regions, including the US, Europe, Middle East, and elsewhere.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/attackers-use-interpol-lure-target-small-businesses>